Araştırma Konusu Önerisi (İnsan-Bilgisayar Etkileşimi)

CAPTCHA Sistemlerinde Güvenlik ve Kullanılabilirlik Dengesi: Kullanıcı Deneyi ve Literatür Temelli Bir Değerlendirme

Ders: İnsan-Bilgisayar Etkileşimi (HCI)

1. Konu Özeti

CAPTCHA'lar ("Completely Automated Public Turing test to tell Computers and Humans Apart"), web sitelerinin insan ile bot ayırt etmek için kullandığı arayüz bileşenleridir ve HCI açısından ilginç bir gerilim noktasıdır: CAPTCHA görevlerini makinelere zorlaştırmak için kullanılan bazı zorlaştırma yöntemleri, insan başarısını ve kullanım kolaylığını da olumsuz etkileyebilir. Bu çalışmada, iki yaygın görünür CAPTCHA türünün (bozulmuş metin ve görsel seçimi) kullanılabilirliği kontrollü bir kullanıcı deneyiyle ölçülecek; güvenlik boyutu ise literatürdeki saldırı çalışmalarından ikinci el olarak derlenecektir. Çalışmanın amacı "en iyi CAPTCHA'yı" belirlemek değil, farklı tasarımların kullanıcıya biçtiği maliyetleri ve literatürde bildirilen güvenlik/erişilebilirlik sınırlılıklarını aynı çerçevede tartışmaktır.

Çalışmada birbirine karıştırılmaması gereken üç kavram ayrıca tanımlanacaktır:

- **Güvenlik (güvenilirlik):** Belirli bir saldırı modeli altında otomatik çözüm ve botlara direnç.
- **Kullanılabilirlik:** İnsanların görevi başarıyla, makul sürede ve kabul edilebilir çabayla tamamlayabilmesi.
- **Algılanan güvenlik:** Kullanıcının sistemin koruyuculuğuna ilişkin öznel değerlendirmesi — gerçek saldırı direnci değildir.

Bu öneride "güvenilirlik" ifadesi botlara karşı güvenlik (ilk madde) anlamında ele alınmıştır.

2. Motivasyon ve Problem Tanımı

CAPTCHA, HCI literatürünün "security-usability trade-off" (güvenlik–kullanılabilirlik dengesizliği) sorununa en görünür örneklerden biridir. İnsan performansına ilişkin temel bulgular:

- İnsan performansına yönelik ilk büyük ölçekli değerlendirme (Bursztein vd., IEEE S&P 2010), 13 görsel ve 8 işitsel şemadan toplanan 318.000'den fazla CAPTCHA örneği havuzu üzerinde insanlara görevler çözdürmüş ve CAPTCHA'ların insanlar için tasarlandığından çok daha zor olduğunu göstermiştir: görsel CAPTCHA'lar ortalama **9,8 saniyede**, işitsel CAPTCHA'lar **28,4 saniyede** çözülmüştür. Çözüm doğruluğu yerine bir yaklaşım ölçüsü olarak üç kişinin aynı cevapta anlaşma oranı kullanıldığında, görsellerde **%71**, işitsellerde **%31,2** düzeyinde kalmıştır (Kaynak: Stanford NLP — Bursztein vd. 2010).

- Güncel ve büyük ölçekli bir kullanıcı çalışması (1.400 katılımcı, 14.000 CAPTCHA; Searles vd., USENIX Security 2023) türler arası önemli farklar bulmuştur; ayrıca çözüm süresi ile kullanıcı algısının her zaman örtüşmediğini ve deneyin yapıldığı bağlamın (CAPTCHA'yı doğrudan çözmek ile gerçek bir görevin parçası olarak çözmek) sonucu etkileyebildiğini göstermiştir (Kaynak: arXiv 2307.12108).
- Aynı çalışmanın derlediği saldırı literatürüyle karşılaştırıldığında, karşılaştırılabilir türlerde botların doğruluğu **%85–100** bandında rapor edilirken insan doğruluğu **%50–84** bandında kalmakta; botlar saniyenin altında, insanlar ise saniyeler ile 15 saniye arasında değişen sürede çözmüştür (Kaynak: arXiv 2307.12108; özet haber: TechXplore). Bu aralıklar belirli türler ve saldırı koşulları için bildirilmiştir; tüm CAPTCHA'lara yaygın bir sonuç olarak okunmamalıdır.

Bu tablo, denge sorusunun artık yalnızca "zorluk ayarı" olmadığını gösterir: Görünür görevler zorlaştırıldıkça insan maliyeti artmakta; otomasyon (bilgisayarla görü, son yıllarda görsel-dil modelleri) ilerledikçe görevin güvenlik getirisi de aşınabilmektedir — bir ön çalışma, görsel-dil modellerinin yaygın görsel CAPTCHA'ların çoğunu çözebildiğini bildirmektedir (Kaynak: arXiv 2502.05461).

Erişilebilirlik boyutu: CAPTCHA görevlerinin doğası gereği birçok engelli kullanıcıyı dışarıda bırakması, W3C'nin "Inaccessibility of CAPTCHA" taslak grubu notunda "hizmet reddi" (denial of service) olarak tanımlanır (Kaynak: W3C Group Draft Note). WCAG bu nedenle CAPTCHA'lar için alternatif duyu modları talep eder (Kaynak: WCAG SC 1.1.1 — Understanding); ayrıca kimlik doğrulama adımlarında bilişsel işlev testini kısıtlayan bir erişilebilirlik ölçütü getirmiştir — bu ölçüt kimlik doğrulama süreçlerine uygulanır ve istisnaları vardır; genel bir CAPTCHA yasağı olarak okunmamalıdır (Kaynak: WCAG 2.2 SC 3.3.8 — Understanding).

Görünmez çözümün yeni maliyeti: Google'ın belgelerine göre reCAPTCHA v3, kullanıcı etkileşimini kesintiye uğratmadan arka planda 0,0–1,0 arası bir risk skoru üretir (Kaynak: Google Developers). Bu yaklaşım etkileşim sürtünmesini büyük ölçüde kaldırır; ancak davranışsal veri toplama ve karar sürecinin deneyciler dışında olması gibi tartışmalar literatürde ve sağlayıcı tartışmalarında mevcuttur. Bu çalışma görünmez sistemlerin güvenliğini veya mahremiyet etkisini deneysel olarak ölçmeyecek; bunları ilgili kaynakların sınırları içinde tartışma bölümünde ele alacaktır.

Bu tablo, HCI dersinin tam ortasına oturan bir soruyu tanımlar: **Kullanılabilirlik, erişilebilirlik ve (algılanan) güvenlik arasındaki denge, farklı CAPTCHA tasarım yaklaşımında kullanıcı tarafından nasıl deneyimlenmektedir?**

3. Araştırma Soruları

- **RQ1:** İki yaygın görünür CAPTCHA türü (bozulmuş metin, görsel seçimi), ilk denemede doğruluk, görev tamamlama oranı, tamamlama süresi ve yeniden deneme/vazgeçme sayısı bakımından nasıl farklılaşmaktadır?
- **RQ2:** Kullanıcıların CAPTCHA türlerine ilişkin algılanan zorluk/çaba ve algılanan güvenlik değerlendirmeleri nasıl değişmektedir?
- **RQ3:** Kullanıcılar CAPTCHA türleri arasında hangi nedenlerle tercih yapmaktadır?

- **RQ4:** Deneyden elde edilen kullanılabilirlik bulguları, literatürde bildirilen güvenlik ve erişilebilirlik sınırlılıklarıyla birlikte yorumlandığında, her iki yaklaşımın "denge" maliyeti nasıl bir tablo çizmektedir?

Kapsam sınırlaması (önceden sabitlenmiş): Bu tasarım tek başına "en güvenli CAPTCHA'yı" veya kesin bir denge kazananını belirlemez. Güvenlik verisi ikinci el (literatür) kaynaklıdır ve farklı sürüm/veri kümesi/saldırgan koşullarındaki saldırı başarı oranları doğrudan karşılaştırılabilir olmayabilir; bu oranlar birleştirilerek keyfî bir "denge puanı" üretilmeyecektir.

4. İlgili Çalışmalar ve Konumlandırma

İnsan performansı ve kullanılabilirlik:

- Bursztein vd. (2010), insan perspektifinden ilk büyük ölçekli CAPTCHA değerlendirmesidir (Kaynak: Stanford NLP).
- Bursztein vd., Google için kullanılabilirliği iyileştiren şemalar geliştiren "Easy Does It" çalışmasında, üretime alınan şemanın %95,3 insan doğruluğuna ulaştığını bildirmiştir (Kaynak: Easy Does It: More Usable CAPTCHAs).
- Searles vd. (2023), günümüzde yayında olan CAPTCHA'ları değiştirmeden, doğal görev bağlamında değerlendiren güncel çalışmadır (Kaynak: arXiv 2307.12108).
- Metin ve görsel CAPTCHA'ları düşük sadakatli (low-fidelity) yöntemle karşılaştıran bir HCI çalışması mevcuttur (Kaynak: ACM).

Erişilebilirlik: W3C "Inaccessibility of CAPTCHA" grubu notu (açıklayıcı bir taslak not; normatif standart değildir) (Kaynak: W3C) ve WCAG 1.1.1 / 3.3.8 ölçütlerinin "Understanding" belgeleri (Kaynak: WCAG).

Güvenlik tarafı: Metin tabanlı CAPTCHA'lara yönelik genel amaçlı çözücüler (Kaynak: The End is Nigh, USENIX WOOT '14); güncel saldırı derlemesi (Kaynak: arXiv 2307.12108); görsel-dil modeli çözücülerine ilişkin ön çalışma (Kaynak: arXiv 2502.05461).

Davranışsal/görünmez sistemler: reCAPTCHA v3 resmî belgeleri (Kaynak: Google Developers); reCAPTCHA v2 üzerine gerçek dünya kullanıcı çalışması (Kaynak: arXiv 2311.10911).

Konumlandırma: Bu çalışma, Türkçe yönergeler kullanan sınırlı bir katılımcı grubunda, seçilmiş iki CAPTCHA prototipinin kullanılabilirliğini karşılaştıran ve Searles vd. (2023) ile Bursztein vd. (2010) tarafından tanımlanan soruyu küçük ölçekte izleyen bir tekrar/genişletme araştırmasıdır. Görünmez sistemler tartışma bölümünde ele alınır.

5. Yöntem: Deney Tasarımı

5.1 Genel Tasarım

- **Katılımcı içi (within-subjects) tasarım:** Her katılımcı her iki koşulu deneyimler. Sıra etkisini dengelemek için katılımcıların yarısı A–B, diğer yarısı B–A sırasını izler.
- **Koşullar (ikisi görünür):** (1) Bozulmuş metin CAPTCHA, (2) görsel seçimi CAPTCHA (ör. "içinde bisiklet olan kareleri seçin" tipi). Her koşulda sunulacak örnek sayısı, tanınan deneme hakkı ve zaman aşımı süresi pilot çalışmanın ardından sabitlenir. Süre ölçümünün başlangıç noktası (CAPTCHA'nın görünmesi ile form etkileşiminin başlaması ayrımı) önceden tanımlanır ve raporlanır.
- **Görünmez/risk tabanlı sistemler deneye üçüncü koşul olarak eklenmez** (kullanıcı görevi ve karar mekanizması farklıdır); bunlar RQ4 kapsamında, literatür üzerinden tartışma bölümünde değerlendirilir.
- **Bağlam:** Tüm katılımcılar aynı cihaz, ekran ve uygulama koşullarında, basit bir **kayıt formu tamamlama demosu** içinde CAPTCHA'larla karşılaşır. Yerel prototip kullanılır; sonuçlar reCAPTCHA veya hCaptcha ürünlerinin doğrudan performans değerlendirmesi olarak sunulmaz. Sonuçlar "seçilen iki prototip ve uyaran kümesi" için yorumlanır; metin bozulması ve görsel seçimi ayarları belgelenerek raporlanır.
- **Ölçek:** Önce 3–5 kişilik pilot; ardından ders olanaklarına uygun **20–30 kişilik keşifsel (exploratory) örneklem**. Bu sayı istatistik güç analiziyle doğrulanmış yeterlilik olarak sunulmaz.

5.2 Ölçümler

Birincil ölçümler (görevden otomatik kaydedilir):

- İlk denemede doğruluk,
- Görev tamamlama oranı (başarısız ve vazgeçilen görevler görünmez kılınmaz),
- Tamamlama süresi,
- Yeniden deneme, vazgeçme ve zaman aşımı sayıları.

Başarılı çözümlerin süreleri, başarısız ve vazgeçilen görevlerin sayıları ve sona erme süreleriyle **birlikte** raporlanır; zaman aşımına uğrayan denemeler tamamlanmış çözüm süresi gibi ortalamaya katılmaz.

İkincil ölçümler:

- Her koşul sonrası kısa zorluk/çaba değerlendirmesi (tek sayfalık anket),
- Açıkça "algılanan güvenlik" olarak adlandırılan öznel değerlendirme,
- Deney sonunda kısa görüşme (tercih nedenleri).

Ölçüm yükü bilinçli olarak sınırlı tutulur: SUS veya NASA-TLX gibi standart ölçekler varsayılan olarak kullanılmaz; kullanılacak olursalar özgün puanlama yönergesine ve Türkçe sürümün geçerlilik dayanağına dikkat edilir, SUS tek bir CAPTCHA görseli değil değerlendirilen bütün akış için yorumlanır. **Sesli düşünme (think-aloud)** protokolü, süre ölçülen görevlerden ayrı olarak yalnızca pilotda veya görev sonrası görüşmede kullanılır.

5.3 Analiz

- Aynı katılımcının iki koşuldaki sonuçları **eşleştirilmiş** olarak karşılaştırılır; her CAPTCHA denemesi bağımsız kişi gibi sayılmaz.
- Farklar yalnızca ortalama üzerinden değil dağılım ve belirsizlik aralıklarıyla raporlanır.
- Searles vd. (2023), deney bağlamının sonucu etkileyebileceğini gösterdiği için (Kaynak: arXiv 2307.12108), katılımcılar doğal bir kayıt görevi bağlamında görev alır; bağlam etkisi sınırlılıklar bölümünde tartışılır.
- **Algılanan güvenlik yüksekliğinin, gerçek güvenlik yüksekliğinin kanıtı olarak yorumlanmayacağı** önceden sabitlenir.

6. Hipotezler

- **H1:** İki koşul, tamamlama süresi ve ilk denemede doğruluk bakımından farklılaşabilir; farkın yönü RQ1'in araştırma konusudur.
- **H2 (yönsüz, keşifsel):** Algılanan güvenlik ile algılanan zorluk arasındaki ilişki, CAPTCHA türlerine göre farklılaşabilir; bu ilişki bu çalışmanın araştırma sorusudur.
- **H3:** Katılımcı tercihi, kullanılabilirlik ölçümleriyle birebir örtüşmeyebilir; tercih nedenleri nitel olarak incelenir.

Her üç soruda da hangi yönde sonuç alınırsa alınsın çalışma raporlanabilir bir bulgu üretir.

7. Etik ve Kapsam Sınırları

- Gönüllü katılım, bilgilendirilmiş onam, istediği an bırakma hakkı ve kurumun/dersin etik prosedürlerine uyum. Onam formunda, çalışmanın bir kayıt demosu üzerinden CAPTCHA kullanılabilirliğinin değerlendirildiği ve toplanacak veriler (görev süresi, doğruluk, deneme sayıları, anket yanıtları) açıkça belirtilir.
- Demoda gerçek hesap, parola veya gereksiz kişisel veri toplanmaz. Yalnızca onam verilen görev süresi, doğruluk ve deneme kayıtları tutulur; oturum dışı takip yapılmaz.
- Katılımcı özellikleri (yaş, cihaz deneyimi vb.) açıkça raporlanır; kolayda örneklemden bütün kullanıcılara genelleme yapılmaz.
- **Erişilebilirlik sınırlılığı açıkça yazılır:** Bu çalışma ekran okuyucu kullanan veya diğer engelli kullanıcı gruplarını örneklemeye dahil etmez; bu bir sınırlılıktır. Engellilik deneyimi göz bağlama gibi simülasyon yöntemleriyle "temsil edilmiş" sayılmaz. W3C ve WCAG literatürü, erişilebilirlik boyutunun tartışma bölümünde ikincil kaynak olarak kullanılır.

8. Geçerlilik Tehditleri

- **Örneklem:** Kolayda örneklemin genellenebilirliği sınırlıdır; katılımcı özellikleri raporlanır.
- **Prototip-ürün farkı:** Yerel prototip, üretim CAPTCHA'larındaki risk motorlarını içermez; tek bir yerel uygulama bütün bir CAPTCHA türünü temsil etmez. Sonuçlar seçilen prototip ve uyaran kümesi için yorumlanır.
- **Bağlam etkisi:** Deney bağlamının (CAPTCHA'ya odaklı vs. doğal görev) sonuçları etkileyebileceği literatürde gösterilmiştir; tasarım bunu kısmen giderir ama tamamen ortadan kaldırmaz.
- **Öğrenme/alışkanlık:** Sıra dengelenerek azaltılır; kalıntısı sınırlılık olarak raporlanır.
- **Öznel ölçüm:** Algılanan güvenlik, öznel bir değerlendirmedir; güvenlik ölçütüyle karıştırılmaz.

9. Beklenen Katkılar

1. İki yaygın görünür CAPTCHA türünün kullanılabilirlik maliyetlerinin, Türkçe yönergeler kullanan sınırlı bir katılımcı grubuyla küçük ölçekli kontrollü bir deneyden ölçülmesi,
2. Algılanan güvenlik ile görev performansı arasındaki ilişkinin keşifsel olarak betimlenmesi,
3. Kullanılabilirlik bulgularının, literatürdeki güvenlik ve erişilebilirlik sınırlılıklarıyla aynı çerçevede tartışıldığı bir değerlendirme — yani "dengenin" çift yönlü maliyet tablosu,
4. Ders kapsamında, HCI'nin temel kavramlarını (sürtünme, bilişsel yük, erişilebilirlik, algılanan güvenlik) tek bir arayüz bileşeni üzerinden birleştiren bir vaka çalışması.

Kaynaklar

1. Bursztein, E., Bethard, S., Fabry, C., Mitchell, J. C. & Jurafsky, D. (2010). How Good Are Humans at Solving CAPTCHAs? A Large Scale Evaluation. IEEE Symposium on Security and Privacy. https://nlp.stanford.edu/pubs/burszstein_2010_captcha.pdf
2. Bursztein, E. vd. Easy Does It: More Usable CAPTCHAs. https://nlp.stanford.edu/pubs/easy.pdf
3. Searles, A., Nakatsuka, Y., Ozturk, E., Paverd, A., Tsudik, G. & Enkoji, A. (2023). An Empirical Study & Evaluation of Modern CAPTCHAs. USENIX Security 2023. https://arxiv.org/pdf/2307.12108
4. W3C. Inaccessibility of CAPTCHA: Alternatives to Visual Turing Tests on the Web (Group Draft Note, 2021). https://www.w3.org/TR/turingtest/
5. W3C. Understanding Success Criterion 3.3.8 Accessible Authentication (Minimum). https://www.w3.org/WAI/WCAG22/Understanding/accessible-authentication-minimum.html
6. W3C. Understanding Success Criterion 1.1.1: Non-text Content. https://w3c.github.io/wcag21/understanding/non-text-content.html
7. Google. reCAPTCHA v3 — resmî geliştirici belgeleri. https://developers.google.com/recaptcha/docs/v3

8. Dazed & Confused: A Large-Scale Real-World User Study of reCAPTCHAv2. https://arxiv.org/html/2311.10911v2
9. The End is Nigh: Generic Solving of Text-based CAPTCHAs. USENIX WOOT '14. https://www.usenix.org/system/files/conference/woot14/woot14-bursztein.pdf
10. Can't You Tell I am a Human? A Comparison of Common Text and Image CAPTCHAs Using a Low-Fidelity Methodology. ACM. https://dl.acm.org/doi/fullHtml/10.1145/3563137.3563179
11. IllusionCAPTCHA: A CAPTCHA based on Visual Illusion (2025). https://ar5iv.labs.arxiv.org/html/2502.05461